

Exercice : Gestion de crise Cyber

Maël - BTS SIO

5 décembre 2025

1 Partie 1 – Analyse de la situation

Type d'attaque

Il s'agit d'un **Rançongiciel** (ou Ransomware). Un pirate a verrouillé les fichiers pour demander de l'argent.

Deux symptômes visibles

- Des fichiers affichent une extension étrange (ex : `.locked`).
- Un message apparaît sur les postes demandant de payer une rançon.

Deux risques majeurs pour l'entreprise

- **Perte d'accès aux fichiers et blocage du travail** : L'entreprise ne peut plus fonctionner car les documents sont illisibles.
- **Perte financière** : Coût de la rançon (si payée) et coût lié à l'arrêt de la production.

2 Partie 2 – Réactions immédiates

3 premières actions d'urgence (Confinement)

1. **Couper immédiatement tous les réseaux** : Débrancher les câbles réseau des postes et des serveurs pour empêcher la propagation.
2. **Identifier les postes infectés** : Noter quels postes affichent le message de rançon.
3. **Vérifier les sauvegardes** : S'assurer que les copies sont saines et déconnectées du réseau.

Pourquoi ne pas payer la rançon ?

- Rien ne garantit que les pirates fourniront la clé de déchiffrement après le paiement.
- Payer finance les criminels et vous désigne comme une cible facile pour une future attaque.

Services internes à prévenir en priorité

- La Direction (Chef d'entreprise).
- Le service Comptabilité/Finances (pour la gestion du risque financier).
- L'ensemble des employés (pour stopper toute utilisation des postes).

3 Partie 3 – Communication de crise

Message aux employés

OBJET : CONSIGNE URGENTE DE SÉCURITÉ

Nous sommes victimes d'une cyberattaque. Veuillez **éteindre immédiatement votre ordinateur** (bouton d'alimentation) et ne plus le rallumer. N'essayez pas d'accéder à vos fichiers. Le service informatique prend les mesures nécessaires. Nous vous tiendrons informés dès que possible de la reprise du travail. Merci de votre coopération.

2 acteurs extérieurs à informer (Légal)

- **La CNIL** : Obligatoire si des données personnelles (clients ou employés) sont touchées.
- **L'ANSSI ou Cybermalveillance.gouv.fr** : Pour le signalement technique et l'assistance.

4 Partie 4 – Remédiation et prévention

Comment vérifier si les sauvegardes sont exploitables ?

- **Vérifier la date** : S'assurer qu'elles sont assez récentes pour limiter la perte de données.
- **Tester la restauration** : Essayer de restaurer un fichier sur un système isolé (hors réseau) pour vérifier qu'il est lisible et non chiffré.

3 mesures pour réduire le risque de récurrence

- **Mots de passe forts et MFA** : Activer la double authentification pour protéger les accès distants et les comptes administrateurs.
- **Sauvegardes déconnectées** : Conserver une copie des données hors ligne (disque dur externe, bande) inaccessible au virus.
- **Sensibilisation des employés** : Former le personnel à détecter le hameçonnage (phishing) et les pièces jointes suspectes.